

CLICKFIX MULTI-STAGE EXECUTION VIA PCALUA

Hidden WMI process creation, remote WebDAV access and Rundll32 proxy execution.

PRODUCTION CANDIDATE

CONFIDENCE: HIGH

CLICKFIX / PCALUA

Identify the source-observed multi-stage command construction while avoiding broad alerts on pcalua, PowerShell or rundll32 alone.

USER ACTION

PCALUA PROXY

POWERSHELL / WMI

HIDDEN CMD

REMOTE RUNDLL32

REPORT DATE

22 July 2026

VERSION

v2.0

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceProcessEvents

ATT&CK / SCOPE

T1202 · T1047 ·
T1218.011 · T1059.001

Independent defensive research. Source facts, analytical assessment, assumptions and detection logic are intentionally separated. Every query requires environment-specific validation.

01

EXECUTIVE ASSESSMENT

Decision-grade summary for threat research, detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

ClickFix Multi-Stage Execution via Pcalua

A confirmed incident exposed a distinctive nested command chain: Explorer-launched pcalua proxies PowerShell, PowerShell uses WMI to create a hidden process, and cmd invokes rundll32 against a remote path. The public package generalizes that behavior while excluding all environment-specific indicators.

WHY IT MATTERS

Operational detection value

Several evasive execution primitives coexist in one process command line. Their intersection is materially more specific than any single LOLBin and can be reviewed from one endpoint process event.

High 01

ANALYTICAL CONFIDENCE



Focused 02

TELEMETRY COVERAGE



Production Candidate 03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACT

Documented behavior

The observed chain included pcalua, PowerShell, Win32_Process creation, a hidden window, rundll32 and remote-path syntax.

ANALYTICAL ASSESSMENT

Interpretation

The full intersection is assessed as sufficiently specific for a production candidate, subject to local command-line fidelity and prevalence.

DETECTION ASSUMPTION

Required condition

DeviceProcessEvents must preserve the complete nested command without truncation or normalization that removes decisive substrings.

Evidence boundary

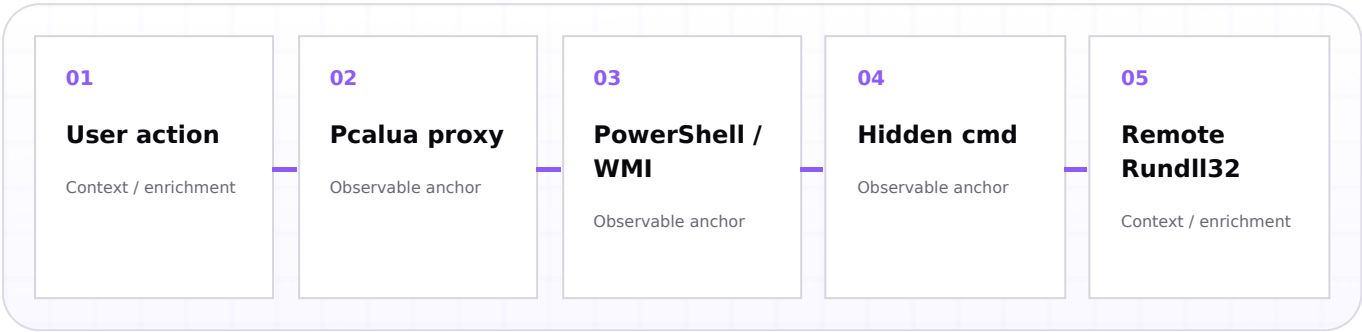
It does not prove clipboard use, the original ClickFix lure, payload execution success, malware family or actor attribution.

02

THREAT MECHANICS

Behavioral decomposition and observable evidence boundaries.

ATTACK FLOW



STAGE-BY-STAGE DETECTION VALUE

STAGE	BEHAVIOR	EVIDENCE EXPECTATION	USE
01	User action	Supporting process, file, identity or application context must be collected and correlated.	Context / enrichment
02	Pcalua proxy	Supporting process, file, identity or application context must be collected and correlated.	Context / enrichment
03	PowerShell / WMI	The observed chain included pcalua, PowerShell, Win32_Process creation, a hidden window, rundll32 and remote-path syntax.	Primary anchor
04	Hidden cmd	Supporting process, file, identity or application context must be collected and correlated.	Context / enrichment
05	Remote Rundll32	Supporting process, file, identity or application context must be collected and correlated.	Context / enrichment

Observable core

A match indicates that one process event retained the high-signal combination of pcalua, PowerShell/WMI hidden-process syntax, rundll32 and remote-path notation.

Non-observable boundary

It does not prove clipboard use, the original ClickFix lure, payload execution success, malware family or actor attribution.

TELEMETRY & EVIDENCE MODEL

Minimum data contract required for a defensible implementation.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Defender XDR · DeviceProcessEvents

The primary platform is selected because it observes the strongest source-supported behavior with the most direct event relationship.

EVIDENCE BOUNDARY

A match is an investigative lead.

It does not prove clipboard use, the original ClickFix lure, payload execution success, malware family or actor attribution.

REQUIRED FIELD CONTRACT

TIER	DATA	PURPOSE	RELIABILITY
REQUIRED	Timestamp, DeviceId, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName, AccountName, SHA1, ReportId	Core filtering, grouping and investigation output.	Documented schema; population must be verified.
OPTIONAL	Signer, hash, prevalence, file origin, software inventory, device group.	Benign separation and prioritization.	Environment-dependent.
ENRICHMENT	Threat intelligence, change windows, asset criticality and identity context.	Disposition and escalation.	Integration-dependent.

Completeness

Confirm table coverage, retention, field population and event latency before measuring prevalence.

Normalization

Validate case, path, quoting, URI encoding and command-line preservation against raw events.

Visibility gap

Changing the LOLBins, WMI syntax or stage boundaries can evade this narrow candidate.

04

DETECTION LOGIC

Source-grounded implementation with explicit assumptions and outcome boundaries.

PRODUCTION CANDIDATE

DETECTION OBJECTIVE

Identify the source-observed multi-stage command construction while avoiding broad alerts on pcalua, PowerShell or rundll32 alone.

IMPLEMENTATION STATUS

Production Candidate - Untested implementation sketch

Syntax and schema are documented; local execution, field population and false-positive performance are not established.

KQL · DEMONSTRATIVE

```
// Title: ClickFix Multi-Stage Execution via Pcalua, WMI and Rundll32
// Status: Production candidate - environment validation required
// Confidence: High
// Platform: Microsoft Defender XDR / Microsoft Sentinel with MDE tables
// Telemetry: DeviceProcessEvents
// Purpose: Detect a highly specific chain in which pcalua proxies PowerShell,
// PowerShell uses WMI to create a hidden process, and rundll32 is instructed
// to execute content from a remote path.
// ATT&CK: T1202, T1047, T1218.011, T1059.001
// Important: This behavior is compatible with an observed ClickFix incident,
// but the match alone does not prove the initial lure or actor attribution.

DeviceProcessEvents
| where Timestamp >= ago(1h)
| where FileName =~ "pcalua.exe"
| where ProcessCommandLine has "powershell"
| where ProcessCommandLine contains "Win32_Process"
| where ProcessCommandLine contains "ShowWindow=0"
| where ProcessCommandLine has "rundll32"
| where ProcessCommandLine contains @"\\\"
| or ProcessCommandLine contains @"SSL\"
| project Timestamp, DeviceId, DeviceName, AccountName,
  ProcessCommandLine, InitiatingProcessFileName,
  InitiatingProcessCommandLine, SHA1, ReportId
```

What a match means

A match indicates that one process event retained the high-signal combination of pcalua, PowerShell/WMI hidden-process syntax, rundll32 and remote-path notation.

What a match does not prove

It does not prove clipboard use, the original ClickFix lure, payload execution success, malware family or actor attribution.

TRIAGE & INVESTIGATION

Evidence-led workflow for defensible disposition.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm the match.
Review the raw event, timestamp, entity relationship and exact matching fields.
- 02

Establish legitimacy.
Identify the software or change owner, expected path, signer and authorized maintenance window.
- 03

Reconstruct origin.
Pivot to process, file, identity, network or application events before and after the match.
- 04

Measure prevalence.
Compare hashes, paths, commands, users and devices across the retained fleet.
- 05

Document confidence.
Separate confirmed evidence, inference, assumptions and unresolved gaps.

DECISION MODEL

Approved context → tune narrowly

Known owner, expected software path and repeatable behavior can support a documented exclusion.

Unknown context → deepen review

Rare or risky context without corroboration remains suspicious or insufficient evidence.

Corroborated activity → escalate

Malicious follow-on process, file, network, persistence or identity evidence supports incident escalation.

Host

Coverage, exposure, recent changes and neighboring alerts.

User

Session, intent, role and authorization context.

Process

Parent, child, path, command, signer and original filename.

File

Hash, signature, origin, prevalence and creation timeline.

Network

DNS, proxy, TLS and destinations following the event.

Identity

Sign-ins, token use, privilege and resource access.

OUTCOME	EVIDENCE PROFILE	ACTION
Benign	Approved and repeatable behavior with strong ownership.	Document and tune narrowly.
Suspicious	Risky context without decisive malicious corroboration.	Deepen endpoint or application review.
Likely malicious	Source-compatible match plus corroborated malicious activity.	Escalate incident response.
Insufficient evidence	Missing telemetry or unresolved ownership.	Retain evidence and validate gaps.

06

FALSE POSITIVES & VALIDATION

Operational controls required before alerting.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	LIKELIHOOD	TUNING ACTION
Administrative compatibility testing	High	Review owner, path, signer, prevalence and change context before exclusion.
Legacy application installers	High	Review owner, path, signer, prevalence and change context before exclusion.
Security simulation	Med	Review owner, path, signer, prevalence and change context before exclusion.
Support tooling with remote resources	Med	Review owner, path, signer, prevalence and change context before exclusion.

Baseline plan

- Run retrospectively over a representative retention window.
- Measure volume by device, user, process, path and software owner.
- Inspect recurring legitimate patterns before adding exclusions.
- Preserve raw examples for peer review.

Validation procedure

- Confirm every required field against raw events.
- Execute only safe, authorized lab or historical validation.
- Compare query output with endpoint or application ground truth.
- Record success, rejection and sensor-failure criteria.

PROMOTION GATE

Hunting

Source-grounded hypothesis.

Candidate

Schema and baseline complete.

Production

Measured precision and runbook.

Optimized

Stable feedback loop.

Promotion criteria

Known alert volume, documented exclusions, representative validation, triage ownership, data-quality monitoring and measurable precision.

Failure condition

Changing the LOLBins, WMI syntax or stage boundaries can evade this narrow candidate.

07

ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

COVERAGE MAPPING

MAPPING	COVERAGE STATEMENT	BOUNDARY
T1202 · T1047 · T1218.011 · T1059.001	Partial behavioral or campaign-artifact coverage of the source-supported observable.	It does not prove clipboard use, the original ClickFix lure, payload execution success, malware family or actor attribution.

ANALYST CONCLUSION

Assessment, not certainty

The intersection is assessed as a high-confidence production candidate, but deployment remains dependent on field completeness, retrospective baseline and controlled validation.

Residual risk

Changing the LOLBins, WMI syntax or stage boundaries can evade this narrow candidate.

REFERENCES

- 1. Think before you Click(Fix): Analyzing the ClickFix social engineering technique: <https://www.microsoft.com/en-us/security/blog/2025/08/21/think-before-you-clickfix-analyzing-the-clickfix-social-engineering-technique/>
- 2. DeviceProcessEvents table in the advanced hunting schema: <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>
- 3. Pcalua: <https://lolbas-project.github.io/lolbas/Binaries/Pcalua/>
- 4. System Binary Proxy Execution: Rundll32 - T1218.011: <https://attack.mitre.org/techniques/T1218/011/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v2.0	22 July 2026	Production Candidate	Detection Engineering

Change summary

Migrated to the permanent Threat Research Editorial HTML master; technical query and evidence classification preserved.

Publication control

No customer data, credentials or environment-specific internal indicators are included. URLs are defanged in the publication artefact.